AI COMPLIANCE SHIELD

EU AI Act
SME Compliance Checklist

A practical, technical readiness guide for startups, SaaS teams and businesses building or using AI systems in the European market.

Built to complement the AI Compliance Shield scanner
Use this checklist alongside your codebase scan, configuration review, dependency checks and prioritised remediation report.

CURRENT EDITION • 10 NOVEMBER 2026

Who this is for

SMEs and startups that develop, provide, integrate, deploy or procure AI-enabled products and services. The checklist is written for founders, product owners, engineering leads, security teams and compliance coordinators.

Important: This is an operational readiness aid, not a legal opinion, certification, conformity assessment or guarantee of compliance. Your duties depend on your role, the intended purpose and risk classification of each AI system, and the applicable law.

How to use this checklist

Work through each section for every AI system or material AI use case. Mark an item complete only when you can point to evidence. Record an owner and a target date for anything still open.

- **1. Inventory:** list AI systems, models, features, vendors and business processes that use AI.
- **2. Classify:** identify your role (provider, deployer, importer, distributor or another operator) and assess whether a prohibited, high-risk or transparency rule may apply.
- **3. Evidence:** keep links to design documents, policies, test results, logs, contracts and approvals.
- **4. Scan:** run the AI Compliance Shield scanner on the relevant project files and review the findings. A code scan is one evidence source; it does not replace legal classification or organisational controls.
- **5. Remediate:** assign an owner and due date, then re-test after changes.

What the AI Compliance Shield scanner is designed to support

The website describes code analysis across common programming languages, configuration review, dependency checks and a PDF report with a compliance score, risk-level breakdown, file-level findings and a prioritised remediation plan. Its stated coverage includes 15 technical requirement areas such as risk management, data governance, transparency, technical documentation, human oversight, accuracy, robustness, cybersecurity and logging. Treat scanner output as technical signals to investigate—not a legal determination.

Official reference points

- Regulation (EU) 2024/1689 (EU AI Act), as amended; use the consolidated text and official guidance for the applicable date and obligations.
- The European Commission AI Act Service Desk and its Compliance Checker / AI Act Explorer provide official guidance and navigation tools.

Key application dates to track

The Act applies in stages. The dates below reflect the European Commission AI Act Service Desk timeline available on 10 November 2026. Always re-check the official timeline before relying on a date.

DATE	WHAT TO TRACK	PRACTICAL ACTION
2 Feb 2025	Definitions, AI literacy provisions and prohibited-practice rules began applying (subject to later amendments to specified prohibitions).	Train relevant staff; screen use cases for prohibited practices; document governance.
2 Aug 2025	GPAI model obligations and governance provisions began applying.	If you provide a general-purpose AI model, assess provider-specific duties; downstream users should review model documentation and terms.
2 Aug 2026	Most AI Act rules apply; Article 50 transparency provisions start applying.	Review AI-generated content disclosure, AI interaction notices and other relevant transparency duties.
2 Dec 2026	Certain additional prohibitions and a transition deadline for Article 50(2) marking obligations for specified systems placed on the market before 2 Aug 2026.	Check whether your system is within the specific amended provisions and transition rule; do not assume it applies to every AI system.
2 Dec 2027	Application date shown for high-risk systems classified under Annex III, subject to the amended framework.	Prepare classification evidence and applicable high-risk controls where relevant.
2 Aug 2028	Application date shown for high-risk AI embedded in regulated products under Annex I.	Coordinate AI Act work with the relevant product-safety / sectoral conformity process.

Date note: the timeline is not a substitute for checking transitional provisions, amendments, system-specific rules or sectoral legislation. The official Commission timeline notes the Digital Omnibus amendments and related transition dates.

1. AI system inventory and ownership

Create one record for each AI system, AI-enabled feature or material AI use case.

- Give the system a unique name, business owner, technical owner and version.
- Describe its intended purpose, users, affected people, deployment context and outputs.
- Record whether the system is developed in-house, customised, integrated from a vendor or supplied as a model/API.
- List the models, datasets, AI services, third-party components and subprocessors used.
- Record where the system is developed, placed on the market, put into service and used—including any EU-facing activity.
- Document material changes, release dates, model updates and changes to intended purpose.

2. Role and risk classification

The AI Act obligations differ according to the operator's role and the system's classification.

- Determine whether the organisation acts as provider, deployer, importer, distributor, product manufacturer or another operator for this use case.
- Record the reasoning and evidence supporting the role determination; a company may have different roles for different systems.
- Assess whether the system falls within the AI system definition and whether an exclusion or special regime may apply.
- Screen the intended purpose and actual use against the prohibited AI practices in Article 5, including the amended provisions and effective dates.
- Assess whether the system may be high-risk under Article 6 and Annex III, or as a safety component / product covered by Annex I.
- Where relying on an exception or non-high-risk route, document the legal basis, assessment, safeguards and any required registration or record.
- Reassess classification when the system's purpose, functionality, deployment context, user group or applicable law changes.

3. AI literacy and staff readiness

AI literacy is an organisation-wide practical responsibility; training should fit people's roles and use of AI.

- Identify staff and contractors who operate, select, configure, monitor or rely on AI systems.
- Provide role-appropriate training on system capabilities, limitations, foreseeable risks and human review.
- Explain when AI outputs must be checked and when they must not be used as the sole basis for a decision.
- Keep training materials, attendance records, completion dates and refresh history.
- Provide escalation guidance for unsafe, biased, inaccurate or unexpected outputs.

4. Risk management and impact assessment

Use a documented, proportionate process. Additional formal assessments may apply to specific high-risk systems and deployers.

- Maintain a risk register covering health, safety, fundamental rights, privacy, security and operational risks relevant to the use case.
- Identify foreseeable misuse, vulnerable or affected groups, failure modes and downstream impacts.
- Define risk owners, mitigation actions, residual risk acceptance and review dates.
- Where required, establish and maintain the AI Act risk-management system across the system lifecycle.
- Determine whether a fundamental rights impact assessment is required for your deployer context under Article 27.
- Check whether a data protection impact assessment or other sector-specific assessment is also required.
- Document testing, review, approval and sign-off before deployment and after significant changes.

5. Data governance and privacy

The exact data-governance duties depend on role, risk class, data use and other applicable laws.

- Document data sources, collection purpose, provenance, licensing, consent or other lawful basis where relevant.
- Assess data quality, relevance, representativeness and known gaps for the intended purpose.
- Check for bias, imbalance, missing groups, label errors and data leakage where relevant.
- Define access controls, retention periods, deletion processes and secure transfer arrangements.
- Map personal-data processing and coordinate with GDPR/privacy requirements where applicable.
- Record data preparation, cleaning, filtering, annotation, transformations and dataset versions.
- Ensure vendor and model contracts explain data use, retention, training and confidentiality.

6. Transparency and user communication

Article 50 contains transparency obligations for certain AI interactions and generated or manipulated content. Applicability depends on the system and role.

- Identify whether people interact directly with an AI system and whether they must be informed they are interacting with AI.
- Assess whether generated or manipulated image, audio, video or text outputs trigger disclosure or marking requirements.
- Check whether deepfake or public-interest text disclosure duties apply to your specific use case.
- Where emotion recognition or biometric categorisation is used, assess applicable notification duties and restrictions.
- Make notices clear, accessible, timely and appropriate to the audience and context.
- Record the technical method used for marking or disclosure, where required, and test that it works.
- Review the 2 Dec 2026 transition provision for specified pre-existing systems under Article 50(2); confirm whether your system is in scope.

7. Human oversight and operational controls

Human oversight requirements are especially important for high-risk systems; meaningful review must be practical, not merely nominal.

- Define who can monitor the system and who has authority to intervene, override, stop or roll back it.
- Give reviewers sufficient training, time, context and access to information to understand outputs and limitations.
- Prevent automation bias by requiring appropriate verification for consequential outputs.
- Set escalation paths for uncertain, harmful, discriminatory or anomalous results.
- Log human interventions, overrides, approvals and incidents where appropriate.
- Test fallback, shutdown and rollback procedures before release.

8. Technical documentation, logging and traceability

Build an evidence trail that explains what the system is, how it is used and how important decisions are controlled.

- Maintain an architecture diagram, system description, intended purpose and version history.
- Document model choice, key parameters, dependencies, interfaces, limitations and known failure modes.
- Keep technical documentation required for the applicable role and risk category.
- Enable and protect logs needed for traceability, monitoring, incident investigation or legal obligations.
- Define log access, integrity protections, retention and deletion rules.
- Link each important compliance claim to evidence, an owner and a review date.
- Keep change records for code, prompts, model versions, datasets, configurations and production releases.

9. Accuracy, robustness and cybersecurity

Translate quality and security goals into measurable tests and operational controls.

- Define expected performance and acceptable error rates for the system's intended purpose.
- Test across relevant user groups, edge cases, languages, environments and operating conditions.
- Evaluate robustness against foreseeable input variation, data drift and adversarial manipulation.
- Use secure development practices, code review, secrets management and least-privilege access.
- Scan dependencies and track vulnerabilities, patch status and software/model supply-chain risks.
- Protect model endpoints, training data, prompts, logs and outputs against unauthorised access or leakage.
- Monitor production performance and security; define thresholds that trigger investigation or rollback.

10. Provider, deployer and supplier coordination

AI Act responsibilities can be distributed across the value chain. Contracts and practical cooperation matter.

- Identify the provider and deployer for each system and document the allocation of responsibilities.
- Obtain available instructions for use, model documentation, limitations, performance information and relevant compliance evidence from suppliers.
- Review vendor terms for permitted use, data handling, security, updates, incident notification and audit cooperation.
- Assess whether a substantial modification or change of intended purpose could change your role or obligations.
- Define who handles user notices, monitoring, logs, complaints, incidents and regulator requests.
- Keep supplier due diligence and periodic reassessment records.

11. Monitoring, incidents and corrective action

Compliance work continues after launch. Make monitoring and response operational.

- ■ Assign an owner to monitor performance, misuse, complaints, drift, security events and emerging risks.
- ■ Create an incident intake process with severity levels, triage steps and escalation contacts.
- ■ Preserve relevant evidence and logs when investigating a suspected incident.
- ■ Define corrective actions, user communications, suspension and rollback criteria.
- ■ Check whether serious-incident reporting or other notification duties apply to your role and system.
- ■ Track remediation to closure and verify that the fix works.

12. Release gate and evidence pack

Use this final gate before launch, material change or a periodic compliance review.

- ■ Confirm the inventory, role analysis and risk classification are current and approved.
- ■ Confirm required notices, human oversight, testing, documentation and security controls are in place.
- ■ Confirm unresolved high-severity findings have an approved treatment and accountable owner.
- ■ Store the latest scanner report alongside manual assessments, approvals and supporting evidence.
- ■ Set the next review date and triggers for an out-of-cycle review.
- ■ Obtain qualified legal or conformity-assessment support where the system's obligations are uncertain or high impact.

Use the checklist with your AI Compliance Shield scan

The scanner is designed to analyse project code, configuration and dependencies, then provide a technical report with findings and a prioritised remediation plan. Use the workflow below to connect those findings to your organisation's compliance evidence.

STEP	WHAT TO DO	EVIDENCE TO KEEP
1. Prepare	Choose the relevant AI project and confirm you have permission to scan it. Remove secrets and unrelated personal data before upload.	Project name, scope, scan date, approved files.
2. Scan	Run the AI Compliance Shield scanner using the supported upload workflow. Review code, configuration and dependency findings.	Original scan report and tool/version details.
3. Triage	Review each finding; confirm whether it is relevant, false positive, already mitigated or needs action.	Triage notes, severity, affected file, rationale.
4. Remediate	Assign an owner and due date. Fix the issue, update controls or document why no change is needed.	Ticket, pull request, policy or control evidence.
5. Re-test	Re-run the scan after material fixes and verify the result in the target environment.	Follow-up report, test evidence and approval.
6. Maintain	Repeat after significant changes and on a risk-based schedule. Keep legal classification separate from code-level scoring.	Version history, review date, owners and sign-off.

Important limits of automated scanning

A source-code or configuration scan cannot, by itself, determine the intended purpose of an AI system, the organisation's legal role, whether an Annex III or Annex I classification applies, whether an Article 27 assessment is required, or whether all organisational processes meet legal requirements. It may not inspect runtime behaviour, training data, vendor systems or operational controls unless those are specifically included in the scan scope. Use technical findings as inputs to a broader assessment.

Your remediation action plan

Use this worksheet to turn checklist gaps and scanner findings into trackable work.

GAP / FINDING	OWNER	PRIORITY	DUE DATE	STATUS / EVIDENCE

System review record

AI system / product		Review date	
Business owner		Technical owner	
Role / classification status		Next review date	
Scanner report reference		Approver	

Before you close the review

- All applicable checklist items have an evidence reference or a documented action.
- Open findings have owners, due dates and an agreed treatment.
- Legal classification and role have been reviewed by a suitably qualified person where needed.
- The next review date and change triggers have been recorded.

Official sources and important disclaimer

Use these primary sources to confirm the current legal text, application dates and official interpretation. Links are included in the PDF as plain URLs for easy reference.

European Commission — AI Act Service Desk: implementation timeline
https://ai-act-service-desk.ec.europa.eu/en/ai-act/eu-ai-act-implementation-timeline

European Commission — Navigating the AI Act (FAQs)
https://digital-strategy.ec.europa.eu/en/faqs/navigating-ai-act

European Commission — AI Act Explorer
https://ai-act-service-desk.ec.europa.eu/en/ai-act-explorer

EUR-Lex — Regulation (EU) 2024/1689, consolidated text
https://eur-lex.europa.eu/eli/reg/2024/1689

European Commission — EU AI Act Compliance Checker
https://ai-act-service-desk.ec.europa.eu/en/eu-ai-act-compliance-checker

Disclaimer

This checklist is provided for general information and operational planning only. It is not legal advice and does not create a lawyer-client relationship. It is not an official European Commission document, an audit, a conformity assessment, a certification or a statement that any organisation or AI system complies with the EU AI Act. The EU AI Act contains role-specific, risk-based and context-dependent obligations, exceptions and transitional provisions. Laws, guidance and implementation dates may change. Verify the current consolidated legal text and official guidance, and obtain advice from qualified legal or conformity-assessment professionals for decisions about your particular system.

AI Compliance Shield is an independent technical tool. Its scan score and findings are indicators for investigation and remediation; they are not a legal compliance score issued or endorsed by the European Union or the European Commission.

AI COMPLIANCE SHIELD | aicomplianceshield.site

Scan your AI project. Review the evidence. Prioritise the fixes. Keep your compliance work documented.